

# **Actividad 01**

## **ANÁLISIS Y PLANIFICACIÓN DEL PENTEST**

**Escenario: Aurora Market**

**Liz Madelyne Tumbaco Peñafiel**

**Hacker Woman Council - Ethical Hacking**



## 1. Objetivo del Pentest

El objetivo de realizar el pentest a Aurora Market es obtener una visión realista y controlada del nivel de exposición de su aplicación web frente a posibles ataques. La evaluación busca conocer qué tan fácil sería para un tercero identificar puntos de entrada, aprovechar una debilidad de seguridad y acceder a funcionalidades o información que no debería estar disponible para él. Por este motivo, el pentest no debe entenderse únicamente como un listado de vulnerabilidades, sino como un proceso para determinar cuáles de esas debilidades representan un riesgo concreto para el negocio.

En el caso de Aurora Market, la aplicación administra cuentas de usuarios y funcionalidades relacionadas con productos, compras y pedidos. Por ello, la evaluación permitirá analizar si los mecanismos de autenticación y autorización realmente impiden accesos indebidos, si las sesiones se gestionan de forma segura, si los datos introducidos por los usuarios son correctamente validados y si existen fallas que puedan permitir manipular funciones de la plataforma. También se busca conocer qué información podría quedar expuesta en un escenario de compromiso y hasta dónde podría avanzar un atacante utilizando una vulnerabilidad.

El valor para Aurora Market está en transformar estos resultados técnicos en decisiones de seguridad. La organización podrá conocer sus principales puntos de exposición, priorizar las vulnerabilidades según su impacto, corregir debilidades antes de que sean aprovechadas por un atacante real y fortalecer los controles de la aplicación. De esta manera, el pentest aporta evidencia para proteger la continuidad del servicio, las cuentas de los usuarios, los pedidos y la información que la empresa administra.

La evaluación se realizará bajo las condiciones previamente autorizadas por Aurora Market: únicamente sobre la aplicación incluida en el alcance, sin afectar deliberadamente la disponibilidad y evitando modificar o extraer información real de clientes.

## 2. Alcance

### Se evaluará

- Aplicación web de Aurora Market, la cual se brinda una autorización previa por parte de la entidad.
- Metodos de autenticación y gestión de sesiones.
- Registro, inicios de sesiones de usuarios, controles de acceso y autorización.
- Procesos dentro del aplicativo que tengan relacion con productos, compras y pedidos.

### Fuera del alcance

- Cuentas de correo electrónico y endpoints de empleados.
- Proveedores relaciones a la empresa y sistemas de terceros.
- Infraestructura que no forme parte del objetivo autorizado.
- Eliminación, modificación o extracción innecesaria de información real de clientes.

- Cualquier activo o sistema que no haya sido autorizado formalmente.

### 3. Autorización y condiciones

- Autorización documentada de Aurora Market para ejecutar la evaluación de seguridad.
- Definición de las URLs, dominios y activos autorizados.
- Identificación de responsables técnicos y contactos de emergencia.
- Autorización expresa para realizar pruebas de explotación controlada.

#### Condiciones acordadas

- Las pruebas se ejecutarán exclusivamente sobre la aplicación web autorizada.
- Las actividades se realizarán durante horarios de menor actividad para minimizar impactos operativos.
- No se realizarán acciones destinadas a interrumpir deliberadamente la disponibilidad del servicio.
- No se eliminará ni alterará información real de clientes.
- Las pruebas de explotación serán controladas, documentadas y reproducibles.
- Los hallazgos críticos serán comunicados oportunamente al responsable designado por Aurora Market.
- Toda información obtenida durante el pentest será tratada como confidencial.

### 4. Tipo de Pentest

Se elige la modalidad Grey Box porque el equipo de Ethical Hacking tendrá información parcial sobre Aurora Market, incluyendo el objetivo, alcance y características generales de la aplicación, pero no tendrá al principio un conocimiento completo de su infraestructura ni de su código fuente. Esta opción permite recrear un ambiente realista en el que un atacante tiene información restringida y analizar de manera controlada la seguridad de la aplicación.

### 5. Planificación del Pentest

| Elemento                      | Planificación                                                                                                                                             |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Objetivos</b>              | Detectar, validar y registrar las vulnerabilidades y averiguar cómo afectan a Aurora Market y a sus usuarios.                                             |
| <b>Alcance</b>                | Aplicación web autorizada, verificación de identidad, sesiones, usuarios, productos, órdenes y controles de acceso.                                       |
| <b>Permisos y condiciones</b> | Autorización formal, usuarios de prueba, activos determinados, horario con menos actividad y prohibición de alterar la disponibilidad o los datos reales. |

|                                           |                                                                                                                                 |
|-------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| <b>Metodología a utilizar</b>             | Guía de pruebas de seguridad web de OWASP (WSTG), complementada con PTES para organizar las etapas de ejecución.                |
| <b>Recopilación de información previa</b> | tecnologías, dominios, URLs, roles, funcionalidades, arquitectura disponible y mecanismos de autenticación.                     |
| <b>Recursos necesarios</b>                | Burp Suite, Kali Linux, herramientas de análisis, Nmap, ZAP de OWASP y el pentester, quien es el encargado técnico del cliente. |
| <b>Programación del pentest</b>           | Reconocimiento, evaluación de vulnerabilidades, explotación controlada, postexplotación, análisis de resultados e informe.      |

## 6. Horarios propuestos para Pentesting

Aurora Market establece que las pruebas deben realizarse durante horarios de menor actividad. Por ello, se propone separar las actividades pasivas de las actividades que generan solicitudes directas contra la aplicación. OSINT y preparación pueden realizarse en horario laboral, mientras que el reconocimiento activo, los escaneos y la validación controlada se concentrarán en una ventana nocturna. La hora definitiva debe confirmarse con Aurora Market a partir de sus periodos reales de menor tráfico.

| Actividad                    | Horario propuesto | Justificación                                                                                            |
|------------------------------|-------------------|----------------------------------------------------------------------------------------------------------|
| OSINT y preparación          | Horario laboral   | Son actividades principalmente pasivas y permiten preparar el pentest sin generar carga significativa.   |
| Reconocimiento activo        | 23:00–00:30       | Permite identificar servicios y superficie de ataque durante una franja de menor actividad.              |
| Análisis de vulnerabilidades | 00:30–02:30       | Los escaneos pueden generar numerosas solicitudes; realizarlos de madrugada reduce el impacto operativo. |
| Explotación controlada       | 02:30–03:30       | Es la actividad de mayor sensibilidad y debe ejecutarse con autorización y supervisión.                  |
| Cierre y verificación        | 03:30–04:00       | Permite detener herramientas, comprobar el estado de la aplicación y registrar evidencias.               |

## 7. Fases del Pentest

### 7.1. Reconocimiento

El reconocimiento tendrá como finalidad conocer cómo está expuesta la aplicación antes de avanzar al análisis de vulnerabilidades. Primero se recopilará información pública e interna; después se realizará reconocimiento activo controlado sobre los activos autorizados. El objetivo será construir un mapa de la superficie de ataque y entender qué componentes deben ser evaluados posteriormente.

Nmap se utilizará sobre los hosts expresamente autorizados para identificar puertos abiertos y servicios asociados. El análisis permitirá conocer, por ejemplo, si existen servicios HTTP/HTTPS u otros servicios expuestos y qué componentes podrían requerir una revisión específica. Cuando se utilice detección de servicios y

versiones, la información permitirá conocer el software expuesto y orientar la búsqueda posterior de vulnerabilidades conocidas. Es importante aclarar que encontrar un puerto abierto no significa por sí mismo que exista una vulnerabilidad; el resultado sirve para conocer la superficie expuesta.

OWASP ZAP se utilizará inicialmente como proxy para navegar por la aplicación y observar las solicitudes y respuestas HTTP(S). De esta manera se podrán identificar URLs, formularios, parámetros, cookies, métodos HTTP y rutas de navegación. En esta etapa su propósito principal será mapear la aplicación y conocer sus puntos de entrada, no ejecutar todavía la explotación de vulnerabilidades.

### 7.1.1. Información a reconocer

- Dominios, subdominios y URLs autorizadas.
- Direcciones IP y hosts asociados.
- Puertos abiertos y servicios disponibles.
- Versiones de servidores o componentes cuando puedan identificarse.
- Tecnologías, frameworks y servidores web.
- Páginas, formularios, endpoints y parámetros.
- Métodos HTTP, cookies y mecanismos de sesión.
- Mecanismos de autenticación y tipos de usuario.
- APIs o rutas administrativas que formen parte del alcance.

### 7.2. Análisis de vulnerabilidades

Una vez identificada la superficie de ataque, se utilizarán herramientas automáticas y revisión manual para buscar posibles debilidades. El propósito no será aceptar ciegamente los resultados de un escáner, sino utilizarlos como indicadores que deberán ser analizados y posteriormente validados.

| Herramienta                          | Información buscada                                                                                     | Propósito                                                                                    |
|--------------------------------------|---------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| OWASP ZAP                            | Cabeceras inseguras, configuraciones web, contenido expuesto y determinados patrones de vulnerabilidad. | Obtener una primera identificación automatizada de posibles problemas en la aplicación.      |
| Burp Suite                           | Parámetros, sesiones, cookies, respuestas, controles de acceso y flujos de autenticación.               | Realizar análisis manual de la lógica de la aplicación y de sus mecanismos de seguridad.     |
| Nmap                                 | Servicios y versiones expuestas.                                                                        | Relacionar servicios descubiertos con posibles vulnerabilidades o configuraciones inseguras. |
| Nessus / OpenVAS<br>(si se autoriza) | Vulnerabilidades conocidas asociadas a servicios y versiones.                                           | Complementar el análisis técnico de componentes autorizados.                                 |

El análisis se enfocará en autenticación, autorización, gestión de sesiones, validación de entradas, inyección, XSS, exposición de información, configuraciones

inseguras, lógica de negocio y APIs cuando estén presentes. OWASP WSTG servirá como referencia para organizar las pruebas de seguridad web.

### **7.3. Explotación**

Verificar de manera controlada las vulnerabilidades detectadas para confirmar si son En esta actividad no se ejecutarán las pruebas. Se explica cómo se abordarían posteriormente. Las vulnerabilidades que presenten evidencia suficiente serían seleccionadas para una validación controlada, con el objetivo de comprobar si realmente pueden aprovecharse y determinar su impacto. Se priorizarán cuentas y datos de prueba y se evitarán acciones que puedan afectar la disponibilidad.

- Confirmar la reproducibilidad del hallazgo.
- Determinar el nivel de acceso que podría obtener un atacante.
- Comprobar qué funcionalidad o información podría quedar comprometida.
- Obtener evidencia suficiente para documentar el riesgo.

### **7.4. Después de la explotación**

La post-explotación se planifica para conocer hasta dónde podría llegar un atacante después de obtener un acceso inicial. Se utilizará la mínima interacción necesaria para demostrar el impacto, sin buscar persistencia ni extraer información real de clientes.

- Identificar privilegios obtenidos.
- Determinar qué recursos o funcionalidades quedan accesibles.
- Evaluar acceso a funciones de otros perfiles.
- Valorar la posibilidad de escalamiento de privilegios.
- Recopilar únicamente la evidencia necesaria.

### **7.5. Informe**

Documentar los hallazgos identificados, evidencias, impacto, nivel de riesgo y recomendaciones de remediación para que Aurora Market pueda corregir las vulnerabilidades.

- Resumen ejecutivo.
- Metodología y alcance.
- Hallazgos y evidencias.
- Nivel de riesgo e impacto.
- Recomendaciones y plan de remediación.
- Conclusiones.

## **8. Investigación**

Se mantiene OWASP Web Security Testing Guide (WSTG) como metodología principal porque el objetivo del escenario es una aplicación web. La guía permite organizar la evaluación de forma progresiva y cubrir áreas como recopilación de

información, autenticación, autorización, gestión de sesiones, validación de entradas, lógica de negocio y exposición de información.

Esta metodología es adecuada para Aurora Market porque gestiona cuentas de usuarios, productos, compras y pedidos. La metodología permite relacionar las pruebas con riesgos que pueden afectar directamente a la plataforma, como acceso no autorizado, compromiso de cuentas, manipulación de funcionalidades, exposición de información y fallas en controles de entrada.